

Evaluación de los 6 componentes esenciales del modelo MoRCiTO mediante una PoC en una infraestructura crítica del sector de las telecomunicaciones

La infraestructura crítica del sector de las telecomunicaciones seleccionada fue un proveedor de servicios de internet (ISP) en Colombia.

Para realizar el análisis de los resultados se tuvo como punto de partida todas las partes interesadas del diagrama de la **Figura 1** que sugiere el modelo MoRCiTO, pero solo se escogieron aquellas que correspondían de acuerdo a la pertinencia de la evaluación y los roles especificados en la **Tabla 1**.

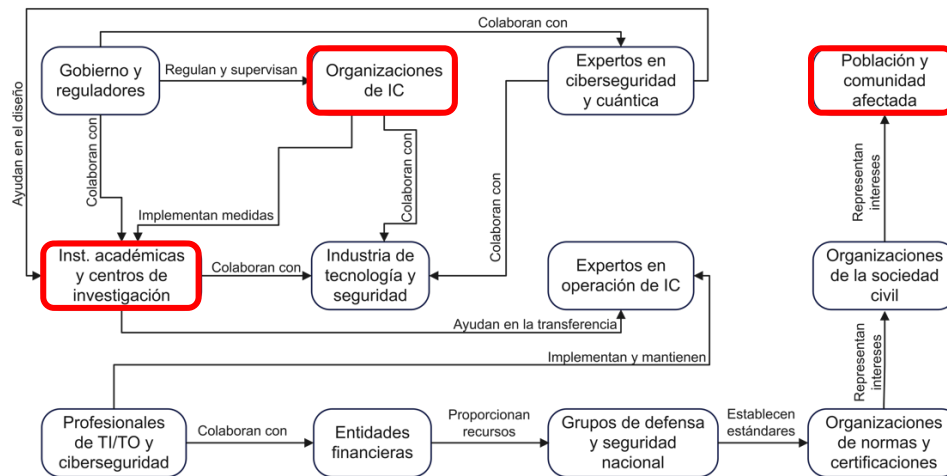


Figura 1. Diagrama de todas las partes interesadas según el modelo de referencia MoRCiTO.

Las partes interesadas que se escogieron para aplicar los instrumentos de los 6 componentes esenciales del modelo de referencia MoRCiTO en el ISP fueron las mostradas en la **Tabla 1**.

Tabla 1. Aplicación del modelo de referencia MoRCiTO de acuerdo a los roles de las partes interesadas del ISP.

No.	*Parte interesada	Rol según el diagrama	Aplicación del modelo de referencia MoRCiTO al ISP
1	Instituciones académicas y centros de investigación	Colaboran con la <i>industria de tecnología y seguridad</i> y ayudan en la transferencia de conocimiento a <i>expertos en tecnología de la operación (TO) en infraestructura crítica (IC)</i> .	Se aplicó la prueba de concepto (PoC) a los cable-módems del ISP en Colombia según el modelo para colaborar con la industria de tecnología y seguridad, y ayudar a la transferencia de conocimiento a expertos de TO para realizar acciones de mejora en el ISP.
2	Organizaciones de IC.	Implementan las medidas de las <i>instituciones académicas y centros de investigación</i> y colaboran con la <i>industria de TO y seguridad</i> .	1. Se entrevistó a uno de los técnicos del ISP que se encargan de instalar los cable-modems. 2. Se consultó el contrato de servicios ofrecidos por el ISP a un beneficiario final del servicio. 3. Se consultó información de los servicios ofrecidos por el ISP en su sitio web oficial.
3	Población y comunidad afectada.	Beneficiarios finales de los servicios o productos ofrecidos por la IC.	Se entrevistó a uno de los usuarios del ISP para identificar sus deberes y derechos relacionados con los productos y servicios recibidos.

*Parte interesada: según el modelo de referencia MoRCiTO.

A partir de los puntajes obtenidos en la escala (0 a 6) presentados en la **Tabla 2**, es posible realizar el análisis de cada uno de los 6 componentes esenciales del modelo teniendo en cuenta los siguientes aspectos: *i.* Fortalezas, *ii.* Oportunidades de mejora importantes, *iii.* Áreas en desarrollo y *iv.* Conclusión. Los aspectos mencionados permiten identificar el nivel de madurez en la implementación de cada componente esencial, determinar sus brechas y priorizar los esfuerzos de mejora. Esto permitirá establecer qué áreas requieren mayor atención, de acuerdo con el modelo MoRCiTO aplicado a la infraestructura crítica evaluada.

Tabla 2. Niveles de implementación del componente esencial del modelo de referencia MoRCiTO según su puntaje, estado y explicación.

*P	Estado	Explicación	Niveles de implementación del componente esencial del modelo de referencia MoRCiTO
[0,1)	No implementado	No se ha considerado ni documentado.	Nivel de Implementación No implementado 1 Planificado 2 En proceso inicial 3 Parcialmente implementado 4 Mayormente implementado 5 Totalmente implementado y optimizado 6 Puntaje Niveles de Implementación de Escala Likert Figura 2. Nivel de implementación vs puntaje.
[1,2)	Planificado	Se ha identificado como una necesidad, pero aún no se ha iniciado la implementación.	
[2,3)	En proceso inicial	Se ha comenzado la implementación, pero con deficiencias importantes.	
[3,4)	Parcialmente implementado	Existe, pero necesita mejoras y optimización.	
[4,5)	Mayormente implementado	Implementado de forma efectiva, con algunas oportunidades de mejora.	
[5,6]	Totalmente implementado y optimizado	Completamente adoptado, con monitoreo y mejoras continuas.	

*P: puntaje en el intervalo [a,b) (se interpreta como que se incluye el valor de a y se excluye el de b), con el último tramo [5,6].

Para facilitar la interpretación del nivel de madurez evaluado, a continuación en la **Tabla 3** se resumen las características de los niveles de indicadores de madurez (MIL), adaptado del modelo de madurez de la capacidad de ciberseguridad (C2M2) [1].

Tabla 3. Equivalencia de los puntajes para evaluar los componentes esenciales y el nivel de indicador de madurez (MIL).

*MIL(0 - 3)	*P	Adaptación del puntaje(0 - 6) de implementación del componente esencial del modelo de referencia MoRCiTO a los indicadores de madurez MIL(0 - 3)
MIL0	$0 \leq P < 2$	Las prácticas no se realizan. Incompleto o no iniciado.
MIL1	$2 \leq P < 4$	Las prácticas iniciales se realizan, pero pueden ser ad hoc (no sistemáticas). Gestionado de forma básica.
MIL2	$4 \leq P < 6$	Características de gestión: - Las prácticas están documentadas. - Se asignan recursos adecuados para apoyar el proceso. Características del enfoque: - Las prácticas son más completas o avanzadas que en el MIL1.
MIL3	$P = 6$	Características de gestión: - Las actividades están guiadas por políticas u otras directrices organizacionales. - Se asignan responsabilidades, rendición de cuentas y autoridad para realizar las prácticas. - El personal cuenta con habilidades y conocimientos adecuados.

*MIL(0 - 3)	*P	Adaptación del puntaje(0 - 6) de implementación del componente esencial del modelo de referencia MoRCiTO a los indicadores de madurez MIL(0 - 3)
		- La efectividad de las actividades se evalúa y se da seguimiento. Características del enfoque: - Las prácticas son más completas o avanzadas que en el MIL2.

*MIL: nivel de indicador de madurez de 0 - 3. *P: puntaje (Valor cuantitativo del puntaje en un rango entre 0 y 6 de los componentes esenciales del modelo de referencia MoRCiTO).

Con base en la **Tabla 3**, la **Figura 3** muestra la equivalencia entre los niveles de madurez MIL y el puntaje de los niveles de implementación de los componentes esenciales del modelo de referencia MoRCiTO en la escala desde 0 a 6.

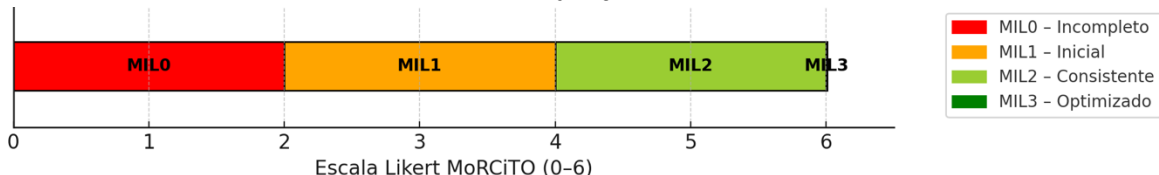


Figura 3. Equivalencia entre los niveles de madurez (MIL) e implementación de un componente esencial de MoRCiTO.

A continuación en la **Tabla 4** se muestra diligenciado el instrumento sobre **políticas de ciberseguridad** que hace parte de los 6 componentes esenciales del modelo MoRCiTO y en la **Tabla 5** el análisis y observaciones de los datos.

Tabla 4. Cuestionario sobre políticas de ciberseguridad.

Pregunta de evaluación	*P	*MIL	Observaciones/evidencia
1. ¿Hasta qué punto existen políticas de ciberseguridad?	3	1	Solo políticas generales del ISP, no aplicadas a dispositivos finales.
2. ¿En qué medida las políticas de ciberseguridad han sido definidas y documentadas?	3	1	Documentación limitada; sin enfoque post-cuántico.
3. ¿Qué tan significativo es la revisión y actualización periódica de políticas?	2	1	No hay evidencia de revisión continua.
4. ¿En qué medida se realizan auditorías internas de ciberseguridad periódicamente?	2	1	Sin auditoría específica a cable módems.
5. ¿Cuál es el grado en que las políticas de ciberseguridad cumplen con estándares internacionales (ejemplo: ISO 27001, IEC 62443)?	2	1	No alineación demostrable con ISO/IEC 27001 ni IEC 62443.
6. ¿Qué tan significativa es la actividad de asignar responsables para la gestión y actualización de políticas de ciberseguridad?	4	2	Roles de soporte definidos, alcance limitado.
7. ¿Cuál es el impacto del procedimiento de documentación de sanciones en caso de incumplimiento de las políticas de ciberseguridad?	1	0	No se aplican sanciones a usuarios/técnicos por fallas.
8. ¿Hasta qué punto se han implementado programas de capacitación en políticas de ciberseguridad?	2	1	Capacitación de seguridad al cliente casi nula.
9. Las políticas incluyen lineamientos específicos para la protección de datos confidenciales	3	1	Políticas de privacidad genéricas, controles técnicos débiles.
10. ¿En qué medida se realiza seguimiento y auditoría sobre el cumplimiento de políticas de ciberseguridad?	2	1	No hay seguimiento sistemático en equipos desplegados.
11. ¿Hasta qué punto las políticas de seguridad se revisan y ajustan en función de los incidentes de ciberseguridad detectados?	2	1	No existe proceso formal de lecciones aprendidas ni ajustes.
Promedios y análisis	2.36	1	Componente esencial: en proceso inicial. Se ha comenzado la implementación, pero con deficiencias importantes. Nivel de madurez MIL1: las prácticas iniciales se realizan, pero

Pregunta de evaluación	*P	*MIL	Observaciones/evidencia
			pueden ser ad hoc (no sistemáticas). Gestionado de forma básica.

*P: puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTO).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

Tabla 5. Análisis y observaciones de los datos del cuestionario sobre políticas de ciberseguridad.

Fortalezas: asignación de responsables (6), se identifica una actividad parcial de delegación de roles de soporte para la gestión de políticas. Aunque limitada en alcance, esta práctica indica un grado incipiente de gobernanza sobre la ciberseguridad.	Oportunidades de mejora importantes: sanciones ante incumplimiento (7), este aspecto no ha sido implementado, lo cual representa una debilidad crítica para la efectividad normativa. La ausencia de consecuencias reduce la disuasión frente al incumplimiento. Seguimiento, auditoría y estándares (3, 4, 5, 10, 11), la falta de revisión sistemática, auditorías internas, alineación con estándares internacionales y mejora continua sugiere una gestión reactiva y no estructurada. Estas carencias afectan la capacidad de adaptarse a nuevas amenazas, incluyendo ciberataques cuánticos.		
Áreas en desarrollo: existencia y documentación de políticas (1, 2, 9), aunque existen políticas generales del ISP, su aplicación específica y técnica a los dispositivos finales es limitada. Tampoco se observan referencias explícitas a entornos post-cuánticos. Esto posiciona el avance en una fase inicial, sin integración efectiva con la operación técnica. Capacitación (8), la formación en políticas de ciberseguridad a clientes o técnicos es prácticamente inexistente. Aun si se tiene documentación, sin formación se pierde aplicabilidad. Este es un factor estructural que afecta el cumplimiento y la cultura organizacional.	Conclusión: El análisis muestra un promedio general de 2.36 , lo que ubica el sistema de políticas de ciberseguridad en un nivel bajo de madurez (MIL0–MIL1). La mayoría de los aspectos están solo planificados o en fases iniciales de implementación, con excepciones específicas como la asignación de responsabilidades. Existen riesgos significativos derivados de la falta de auditoría, control y formación, que deben ser abordados para permitir la transición hacia un modelo de ciberseguridad robusto, especialmente en contextos críticos como los sistemas ciberfísicos (CPS) frente a amenazas cuánticas.		

Nota: Los valores entre paréntesis corresponden al número de la pregunta evaluada en el cuestionario.

A continuación en la **Tabla 6** se muestra diligenciado el instrumento sobre **controles de acceso** que hace parte de los 6 componentes esenciales del modelo MoRCiTO y en la **Tabla 7** análisis y observaciones de los datos.

Tabla 6. Cuestionario sobre controles de acceso.

Pregunta de evaluación	*P	*MIL	Observaciones/evidencia
1. ¿En qué medida se han implementado controles de autenticación multi-factor (MFA) en accesos críticos?	1	0	No implementado en cable módems.
2. ¿Cuál es el grado de implementación de los procedimientos de auditorías del control de acceso periódico?	2	1	Solo revisiones técnicas reactivas.
3. ¿Hasta qué punto se documentan e implementan controles de acceso basados en roles (RBAC)?	2	1	Sin RBAC real en el CPE del cliente.
4. ¿Qué tanto se ha implementado el control de restricción de accesos no autorizados en función del principio de menor privilegio?	2	1	Usuarios tienen credenciales por defecto con privilegios altos.
5. ¿Cuál es el grado de implementación de procedimientos claros para la gestión de privilegios de las cuentas de los usuarios?	1	0	No hay procesos para revocar accesos predeterminados.
6. ¿En qué estado se encuentra la implementación de controles de monitoreo continuo de los accesos a sistemas críticos?	2	1	Monitoreo centralizado limitado, no granular.
7. ¿En qué grado de implementación se encuentran los controles de revisión y	1	0	Sin control sobre accesos externos.

Pregunta de evaluación	*P	*MIL	Observaciones/evidencia
autorización de accesos temporales o de terceros?			
8. ¿Qué tanto se han implementado controles de sistemas de detección de intrusos?	2	1	Limitado a nivel de red ISP, no en los dispositivos.
9. ¿En qué medida se han implementado controles sobre las credenciales de acceso para que sean almacenadas de manera segura y cifradas?	1	0	Contraseñas en texto plano o default.
10. ¿Cuál es el grado de implementación de los procedimientos de auditorías periódicas para revocar accesos innecesarios o inactivos?	1	0	Inexistentes.
Promedios y análisis	1.5	0.5	Componente esencial: planificado. Se ha identificado como una necesidad, pero aún no se ha iniciado la implementación. Nivel de madurez MIL0: las prácticas no se realizan. Incompleto o no iniciado.

*P: puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTO).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

CPE: Customer Premises Equipment (Equipo en las instalaciones del cliente - Cable modems).

Tabla 7. Análisis y observaciones de los datos del cuestionario sobre controles de acceso.

Fortalezas: actualmente no se identifica ningún ítem con nivel de implementación parcial, mayor o total. La inexistencia de fortalezas consolidadas refleja una madurez extremadamente baja en la gestión de controles de acceso para los dispositivos en instalaciones del cliente (CPE).	Oportunidades de mejora importantes: ausencia total de MFA (1), la falta de autenticación multi-factor en accesos críticos representa una vulnerabilidad severa, especialmente considerando que los dispositivos CPE están expuestos a Internet. Credenciales inseguras (9), el uso de contraseñas por defecto o en texto plano debilita completamente cualquier otro control que se pudiera implementar. Falta de gestión de privilegios (5) y revocación de accesos inactivos (10), estos ítems muestran que no hay ningún ciclo de vida del acceso, lo cual pone en riesgo la integridad de los dispositivos. Accesos externos sin control (7), la inexistencia de controles sobre terceros o accesos temporales permite potenciales movimientos laterales dentro de la red del ISP o del cliente.
Áreas en desarrollo: auditorías reactivas (2), RBAC no real (3), monitoreo centralizado limitado (6) y detección de intrusos solo a nivel ISP (8), estas áreas están planificadas o implementadas parcialmente a nivel central, pero no se extienden de forma granular a los dispositivos finales, lo que limita su efectividad práctica. Aplicación parcial del principio de menor privilegio (4), aunque el concepto está reconocido, los usuarios aún operan con privilegios elevados, lo que implica una desalineación entre política e implementación.	Conclusión: El análisis muestra un promedio alarmantemente bajo (1.5), correspondiente a un estado de madurez (MIL0–MIL1), donde la mayoría de los controles de acceso son inexistentes o apenas considerados. La ausencia de MFA, la persistencia de credenciales por defecto, la falta de RBAC y de auditorías proactivas exponen de forma crítica los dispositivos CPE, permitiendo potenciales vectores de intrusión. Este es uno de los dominios con mayor urgencia de intervención, ya que los controles de acceso son la primera línea de defensa contra ataques de red. Es prioritario definir un plan de acción inmediato que permita: <i>i.</i> eliminar accesos por defecto. <i>ii.</i> Incorporar autenticación fuerte (MFA). <i>iii.</i> Diseñar e implementar RBAC y <i>iv.</i> Automatizar auditorías y revisiones de privilegios.

Nota: Los valores entre paréntesis corresponden al número de la pregunta evaluada en el cuestionario.

A continuación en la **Tabla 8** se muestra diligenciado el instrumento sobre detección y respuesta a incidentes que hace parte de los 6 componentes esenciales del modelo MoRCiTO y en la **Tabla 9** el análisis y observaciones de los datos.

Tabla 8. Cuestionario sobre detección y respuesta a incidentes.

Pregunta de evaluación	*P	*MIL	Observaciones/evidencia
1. ¿En qué medida se encuentra implementado un plan de documentación de respuesta a incidentes de ciberseguridad?	2	1	Procedimientos generales ISP, no específicos para módems.

2. ¿Qué tanto se han implementado herramientas de detección de intrusos en la red?	2	1	IDS en red central, no en equipos finales.
3. ¿En qué medida se han implementado simulaciones de respuesta a incidentes periódicamente?	1	0	No se realizan.
4. ¿Cuál es el grado de implementación de un proceso de escalamiento de incidentes según su criticidad?	2	1	Existe a nivel ISP, pero no formalizado para clientes.
5. ¿Existe un equipo de respuesta a incidentes (CSIRT) que se encargue de la detección y respuesta a incidentes?	3	1	ISP cuenta con CSIRT, pero enfocado en red backbone.
6. ¿En qué medida se encuentra implementado un proceso en donde se registren y analicen los ciberincidentes para mejoras futuras?	2	1	Limitado, sin retroalimentación al cliente.
7. ¿Hasta qué punto se han implementado acuerdos de nivel de servicio (SLA) para la respuesta a incidentes?	3	1	Existen SLA, pero solo por disponibilidad de servicio.
8. ¿En qué medida se realizan procesos de capacitación sobre respuesta a incidentes?	2	1	Personal técnico ISP con entrenamiento básico.
9. ¿Hasta qué punto se han implementado mecanismos de comunicación efectiva con autoridades y organismos de ciberseguridad?	1	0	No existe protocolo de reporte externo.
10. ¿A qué nivel se han implementado procedimientos de revisión y mejora del plan de respuesta a incidentes después de haber ocurrido?	2	1	No se documenta aprendizaje tras incidentes.
11. ¿Existe un centro de operaciones de seguridad (SOC) que se encargue de la detección y respuesta a incidentes?	3	1	ISP tiene SOC, pero centrado en core.
Promedios y análisis	2.1	0.8	Componente esencial: en proceso inicial. Se ha comenzado la implementación, pero con deficiencias importantes. Nivel de madurez MIL0: las prácticas no se realizan. Incompleto o no iniciado.

*P: Puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTo).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

Tabla 9. Análisis y observaciones de los datos del cuestionario sobre detección y respuesta a incidentes.

Fortalezas: presencia de CSIRT (5) y SOC (11), aunque centrados en el core de la red del ISP y no en los dispositivos finales, existe una estructura formal que puede ser aprovechada como base para extender capacidades hacia los CPE. Esto representa un avance inicial hacia la institucionalización de la respuesta a incidentes. SLA por disponibilidad (7), si bien son limitados, los SLA existentes muestran un compromiso básico con la estabilidad del servicio, lo que puede evolucionar hacia acuerdos más específicos orientados a ciberseguridad.	Oportunidades de mejora importantes: falta de simulaciones de incidentes (3), la ausencia total de pruebas o simulacros de respuesta compromete seriamente la capacidad de reacción real ante ciberataques. Sin mecanismos de reporte a autoridades (9), no hay ningún protocolo de comunicación con CERTs u otras autoridades de ciberseguridad, lo cual limita la colaboración ante incidentes a gran escala. Ausencia de procesos de mejora tras incidentes (10), la falta de documentación o retroalimentación posterior impide el aprendizaje organizacional, esencial en una gestión madura de incidentes.
Áreas en desarrollo: plan de respuesta no adaptado al contexto (1), aunque existe a nivel del ISP, el plan no incluye a los equipos de cliente, lo cual es una brecha crítica en la cadena de responsabilidad. Capacitación básica (8), hay formación mínima para técnicos, pero no se ha expandido a todos los niveles operativos ni incluye escenarios reales de ataque. Herramientas IDS (2): La detección de intrusos está implementada parcialmente en la red backbone, sin cobertura específica para los dispositivos finales.	Conclusión: El puntaje promedio de 2.1 indica un estado de madurez bajo (MIL0–MIL1). La mayoría de los procedimientos se encuentran planificados o en una etapa muy incipiente de ejecución, con algunos elementos estructurales ya disponibles (como CSIRT y SOC) que podrían escalarse hacia un modelo de respuesta más robusto e inclusivo para todos los activos del ISP, incluyendo los Customer Premises Equipment (CPE). Para avanzar en este dominio es prioritario: <i>i.</i> Establecer un protocolo de reporte y comunicación con autoridades externas. <i>ii.</i> Documentar, probar y revisar el plan de respuesta a incidentes para incluir a los CPE. <i>iii.</i> Implementar simulaciones periódicas y mecanismos formales de aprendizaje post-incidente.

Nota: Los valores entre paréntesis corresponden al número de la pregunta evaluada en el cuestionario.

A continuación en la **Tabla 10** se muestra diligenciado el instrumento sobre **gestión de riesgos** que hace parte de los 6 componentes esenciales del modelo MoRCiTO y en la **Tabla 11** análisis y observaciones de los datos.

Tabla 10. Cuestionario sobre gestión de riesgos.

Pregunta de evaluación	*P	*MIL	Observaciones/ evidencia
1. ¿Hasta qué punto se realizan evaluaciones formales de riesgos de manera periódica?	2	1	No existen evaluaciones periódicas en CPE.
2. ¿En qué medida se han implementado procedimientos de identificación de riesgos específicos relacionados con ciberataques cuánticos?	1	0	No considerada en políticas del ISP.
3. ¿A qué nivel se han implementado medidas de mitigación al identificar los riesgos?	2	1	Mitigación reactiva (reinicio/reset de equipos).
4. ¿Hasta qué punto se cuenta con la implementación de un procedimiento de revisión continua de riesgos emergentes?	1	0	Inexistente.
5. ¿En qué medida se han implementado planes de acción ante escenarios de ciberataques cuánticos?	1	0	No contemplados.
6. ¿A qué nivel se han implementado políticas de monitoreo y control de riesgos?	2	1	Monitoreo genérico, no enfocado en ciber-riesgos.
7. ¿Hasta qué punto se han implementado pruebas de resiliencia y continuidad del negocio (BCP)?	2	1	ISP posee planes, pero no aplican a dispositivos cliente.
8. ¿Hasta qué punto se han implementado mecanismos de reporte de incidentes relacionados con riesgos cuánticos?	1	0	No existe.
9. ¿A qué nivel se han implementado procedimientos de análisis de riesgos y que se encuentren alineados con algún framework o taxonomía (Ejemplo: NIST RMF, ISO 31000 o TRACI)?	1	0	No aplicados.
10. ¿Hasta qué punto se han implementado procedimientos en el que los resultados de las evaluaciones de riesgos se usan para ajustar estrategias de ciberseguridad?	1	0	Inexistente.
Promedios y análisis	1.4	0.4	Componente esencial: planificado. Se ha identificado como una necesidad, pero aún no se ha iniciado la implementación. Nivel de madurez MIL0: las prácticas no se realizan. Incompleto o no iniciado.

*P: Puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTO).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

CPE: Customer Premises Equipment (Equipo en las instalaciones del cliente - Cable modems).

Tabla 11. Análisis y observaciones de los datos del cuestionario sobre gestión de riesgos.

Fortalezas: actualmente no se identifican fortalezas claras. Ningún ítem supera el nivel 2 (planificado), lo que sugiere que no existe una gestión madura de riesgos específica ni siquiera incipiente para los dispositivos del cliente (CPE). No obstante, el hecho de que varios aspectos estén "planificados" sugiere al menos conciencia organizacional inicial del problema.	Oportunidades de mejora importantes: Ausencia total de planificación ante ciberataques cuánticos (2, 5, 8, 9), no se contemplan riesgos cuánticos en las políticas, procedimientos o mecanismos de reporte. Esta omisión es grave considerando que este cuestionario forma parte de una evaluación anticipatoria de amenazas futuras. (MIL0) Sin aprovechamiento de resultados para ajustar estrategias (10), no se utiliza la información de las evaluaciones para optimizar la postura de ciberseguridad, lo cual bloquea el ciclo de mejora continua. Revisión de riesgos emergentes inexistente (4), en un entorno de amenazas cambiantes, no contar con esta capacidad representa una vulnerabilidad estructural, especialmente para infraestructuras críticas.
Áreas en desarrollo: evaluaciones de riesgo formales (1), si bien no se realizan de forma periódica, este aspecto se encuentra al menos planificado, lo que podría permitir su implementación a corto plazo si se asignan recursos y roles	Conclusión: El resultado promedio de 1.4 ubica a este dominio en un estado de no implementación (MIL0) con algunas intenciones de desarrollo incipiente (planificado en 4 de 10 ítems). La gestión de riesgos en los CPE es

específicos. Mitigación reactiva (3), las acciones actuales (ej. reinicio de equipos) son reacciones técnicas básicas, sin un enfoque estratégico de gestión de riesgos. Se requiere evolucionar hacia respuestas proactivas y automatizadas. Políticas de monitoreo y BCP (6, 7), existen a nivel de ISP pero no se extienden a los dispositivos CPE. Esta es una brecha de aplicación que puede solucionarse mediante ampliación de cobertura o segmentación de controles.	prácticamente inexistente, especialmente en lo referente a amenazas cuánticas, continuidad del negocio y alineación con marcos de referencia reconocidos. Es indispensable: <i>i.</i> Introducir un modelo sistemático de evaluación y priorización de riesgos, idealmente alineado con TRACI, ISO 31000 o NIST RMF. <i>ii.</i> Diseñar políticas específicas para entornos cuánticos, incluyendo simulaciones y planes de acción. <i>iii.</i> Activar mecanismos formales de retroalimentación y adaptación estratégica.
--	--

Nota: Los valores entre paréntesis corresponden al número de la pregunta evaluada en el cuestionario.

A continuación en la **Tabla 12** se muestra diligenciado el instrumento sobre criptografía y seguridad de comunicación que hace parte de los 6 componentes esenciales del modelo MoRCiTO y en la **Tabla 13** el análisis y observaciones de los datos.

Tabla 12. Cuestionario sobre criptografía y seguridad de comunicación.

Pregunta de evaluación	*P	*MIL	Observaciones/ evidencia
1. ¿A qué nivel se han implementado procedimientos de criptografía post-cuántica en sistemas críticos?	1	0	No implementada.
2. ¿En qué medida se han implementado procedimientos de identificación y sustitución de algoritmos criptográficos vulnerables?	2	1	Uso de TLS desactualizado en algunos equipos.
3. ¿Hasta qué punto se han implementado procedimientos de documentación de pruebas de ciberseguridad en comunicaciones cifradas?	1	0	No existe.
4. ¿Cuál es el grado de implementación de un plan de transición a criptografía post-cuántica?	1	0	No definido.
5. ¿A qué nivel se han implementado procedimientos de distribución de claves que incluyan QKD o soluciones híbridas?	1	0	No implementada.
6. ¿En qué medida se han implementado procedimientos de evaluación de vulnerabilidades en infraestructuras de cifrado existente?	2	1	Limitada y reactiva.
7. ¿Hasta qué punto se han implementado procedimientos en que las comunicaciones críticas estén protegidas contra posibles ciberataques cuánticos?	1	0	Inexistente.
8. ¿Cuál es el grado de implementación de los procedimientos de auditorías periódicas para validar la efectividad de la criptografía usada?	1	0	No implementadas.
9. ¿A qué nivel se han implementado procedimientos de cifrado de datos almacenados y en tránsito que cumplen con estándares actualizados?	2	1	Parcial (solo algunos canales de administración).
10. ¿Hasta qué punto se han implementado programas de capacitación al personal idóneo en criptografía post-cuántica?	1	0	No se contempla.
Promedios y análisis	1.3	0.3	Componente esencial: planificado. Se ha identificado como una necesidad, pero aún no se ha iniciado la implementación. Nivel de madurez MIL0: las prácticas no se realizan. Incompleto o no iniciado.

*P: Puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTO).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

Tabla 13. Análisis y observaciones de los datos del cuestionario sobre criptografía y seguridad de comunicación.

Fortalezas: Actualmente no se evidencian fortalezas. Ningún ítem alcanza niveles de implementación parcial mayor o igual a 3, lo que refleja una ausencia total de capacidades criptográficas avanzadas o post-cuánticas en	Oportunidades de mejora importantes: Criptografía post-cuántica (1, 4, 5, 7), no hay ninguna implementación ni planificación relacionada con mecanismos resistentes a la computación cuántica. Esta ausencia en un dominio clave del
--	---

los dispositivos evaluados. Sin embargo, hay signos de planificación básica en algunos aspectos (ver áreas de desarrollo).	modelo MoRCiTO representa un riesgo estructural grave, especialmente considerando las amenazas emergentes en infraestructuras críticas. Protección de comunicaciones cifradas (3, 7), no existen mecanismos que documenten pruebas de seguridad en los canales cifrados ni tampoco hay protección específica contra ataques cuánticos. Esta debilidad expone la confidencialidad e integridad de las comunicaciones críticas. Capacitación técnica (10), la falta de formación del personal en criptografía post-cuántica significa que incluso si se implementaran soluciones, no habría competencias internas para operarlas ni gestionarlas. Auditorías criptográficas inexistentes (8), no hay procesos de validación ni revisión sobre la efectividad de la criptografía en uso. Esta es una omisión crítica que impide detectar errores, configuraciones inseguras o degradación del cifrado en el tiempo.
Áreas en desarrollo: Uso parcial de TLS y cifrado (2, 6, 9), aunque obsoletos o mal configurados, se identifican indicios de cifrado en algunos canales y acciones reactivas ante vulnerabilidades, lo que sugiere que existe conciencia del problema, aunque sin una estrategia sólida. Estas áreas podrían ser priorizadas como puntos de partida para avanzar hacia una postura más segura.	Conclusión: El resultado promedio de 1.3 sitúa a este dominio en un estado de no implementación (MIL0). La gestión de criptografía y seguridad en las comunicaciones es extremadamente débil en los dispositivos de cliente (CPE), sin evidencias de mecanismos modernos ni enfoque cuántico-resistente. La ausencia de implementación se hace más crítica considerando que: <i>i.</i> Las comunicaciones del CPE son un punto de entrada habitual para atacantes. <i>ii.</i> Los algoritmos actuales (e.g., RSA, ECC) serán vulnerables a corto o mediano plazo por los avances en computación cuántica.

Nota: Los valores entre paréntesis corresponden al número de la pregunta evaluada en el cuestionario.

A continuación en la **Tabla 14** se muestra diligenciado el instrumento sobre **actualización y parches de seguridad** que hace parte de los 6 componentes esenciales del modelo MoRCiTO y en la **Tabla 15** análisis y observaciones de los datos.

Tabla 14. Cuestionario sobre actualización y parches de ciberseguridad.

Pregunta de evaluación	*P	*MIL	Observaciones/ evidencia
1. ¿En qué medida hay un procedimiento implementado que documente la gestión de actualizaciones de ciberseguridad?	2	1	ISP define guías generales, pero no aplicadas a usuarios.
2. ¿A qué nivel se han implementado procedimientos para aplicar parches de ciberseguridad de manera periódica?	2	1	Muchos equipos obsoletos.
3. ¿Hasta qué punto se han implementado procedimientos para realizar pruebas de compatibilidad antes de cada actualización?	1	0	No documentadas.
4. ¿A qué nivel se han implementado estrategias de actualización para SCF(Ejemplo: SCADA/ICS)?	1	0	No existen.
5. ¿En qué medida se han implementado procedimientos de actualizaciones de firmware y software que se apliquen de manera controlada?	2	1	Solo en casos de soporte reactivo.
6. ¿A qué nivel se han implementado mecanismos de retroceso (rollback) en caso de fallos durante las actualizaciones?	1	0	No implementados.
7. ¿En qué medida se han implementado procedimientos para registrar de manera detallada las actualizaciones aplicadas?	1	0	No se lleva histórico.
8. ¿Hasta qué punto se han implementado planes para identificar sistemas críticos que requieran actualizaciones específicas?	2	1	No priorizados.

Pregunta de evaluación	*P	*MIL	Observaciones/ evidencia
9. ¿Cuál es el grado de implementación de una política de evaluación de impacto antes de realizar actualizaciones?	1	0	Inexistente.
10. ¿A qué nivel se ha implementado un proceso de actualización que considere los riesgos de interrupción en la operación?	1	0	Inexistente.
Promedios y análisis	1.4	0.4	Componente esencial: planificado. Se ha identificado como una necesidad, pero aún no se ha iniciado la implementación. Nivel de madurez MIL0: las prácticas no se realizan. Incompleto o no iniciado.

*P: Puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTO).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

Tabla 15. Análisis y observaciones de los datos del cuestionario sobre actualización y parches de ciberseguridad.

Fortalezas: Actualmente no se identifican fortalezas destacables. Ningún ítem supera el nivel 2 (planificado), lo que indica que no hay prácticas consolidadas ni procesos maduros relacionados con la gestión de actualizaciones y parches en los dispositivos CPE.	Oportunidades de mejora importantes: Pruebas de compatibilidad y rollback inexistentes (3, 6), no se realizan pruebas previas ni se contemplan mecanismos de retroceso ante fallos, lo que aumenta el riesgo de interrupciones críticas y pérdida de disponibilidad. Ausencia de estrategias para sistemas industriales SCF/ICS (4), no existe ninguna política o protocolo que considere la actualización segura en entornos industriales o de misión crítica, lo cual es alarmante para infraestructuras críticas. Evaluación de impacto y gestión de riesgos operativos nula (9, 10), no se contemplan impactos derivados de parches en la continuidad operativa. Esta omisión impide la implementación segura y controlada de cambios. No hay registro histórico (7), la ausencia de trazabilidad imposibilita la verificación, auditoría y aprendizaje posterior a errores o vulnerabilidades ya corregidas.
Áreas en desarrollo: Documentación y aplicación de parches (1, 2, 5), aunque de manera limitada, el ISP define guías generales y realiza parches en modo reactivo. Estos elementos podrían formalizarse en políticas proactivas con alcance al cliente final. Identificación de sistemas críticos (8), existe una intención de establecer prioridades, aunque no se ha traducido en una clasificación o plan específico. Esto ofrece un punto de partida para mejorar selectividad y eficiencia de los parches.	Conclusión: Con un puntaje promedio de 1.4, el dominio de actualización y gestión de parches se encuentra en nivel MIL0–MIL1, es decir, no implementado o solo planificado. La gestión de parches, actualizaciones y mantenimiento en los dispositivos del cliente (CPE) se presenta como altamente reactiva, no estructurada y sin trazabilidad ni respaldo técnico preventivo. Las ausencias más críticas incluyen: <i>i.</i> Pruebas previas, control de fallos, y rollback. <i>ii.</i> Evaluación de impacto y continuidad operativa. <i>iii.</i> Registros históricos de cambios y documentación formal. <i>iv.</i> Adaptación a entornos críticos como SCADA/ICS.

Nota: Los valores entre paréntesis corresponden al número de la pregunta evaluada en el cuestionario.

Es de resaltar que el único componente esencial que se acerca un poco al umbral aceptable de implementación es el llamado *políticas de seguridad*, como se muestra en la **Figura 4** y las recomendaciones mencionadas en la **Tabla 16**, lo cual debe alertar a la infraestructura crítica a priorizar sus esfuerzos de mejora en todos los componentes evaluados según el modelo MoRCiTO.

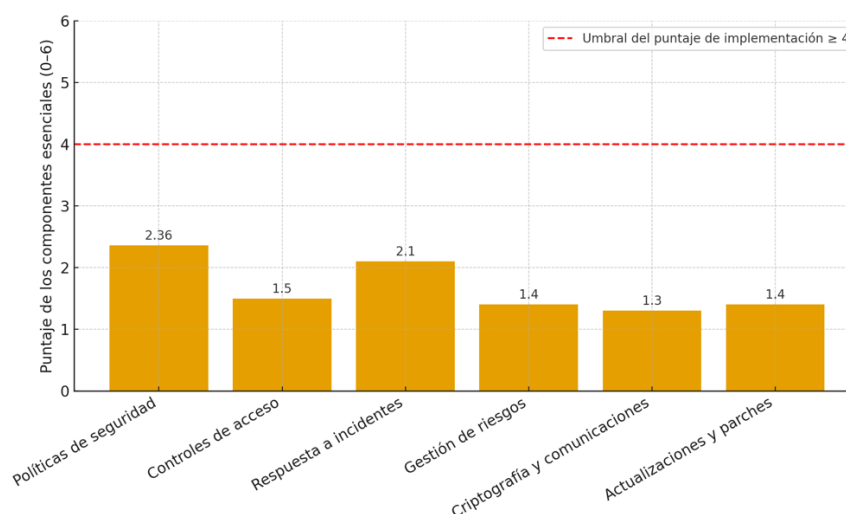


Figura 4. Puntaje de los componentes esenciales del ISP vs umbral según la escala del modelo de referencia MoRCiTO.

A continuación, en la **Tabla 16** se resumen todos los hallazgos encontrados en cada uno de los componentes esenciales del modelo MoRCiTO aplicado al ISP evaluado y sus respectivas recomendaciones de mejora con base en los resultados identificados.

Tabla 16. Recomendaciones del modelo MoRCiTO en cada uno de los 6 componentes esenciales del ISP.

Componentes esenciales de MoRCiTO	*MIL	*P	Hallazgos / Comentarios según C2M2	Recomendaciones según MoRCiTO
Políticas de ciberseguridad	1	2.36	Existen políticas generales a nivel del ISP, pero no aplicadas a dispositivos finales. No hay revisión periódica, ni cumplimiento con estándares.	Formalizar políticas específicas para CPE; revisarlas tras incidentes; alinear con ISO/IEC 27001 e IEC 62443; capacitar usuarios y técnicos.
Controles de acceso	0	1.5	No se ha implementado MFA ni gestión de privilegios. Credenciales por defecto y sin auditorías o control de accesos temporales.	Eliminar credenciales por defecto; implementar MFA y RBAC; centralizar la gestión de identidades y revocación de accesos.
Detección y respuesta a incidentes	1	2.1	Existen CSIRT y SOC a nivel de ISP backbone, pero sin cobertura para CPE. No hay simulaciones, retroalimentación ni protocolos con autoridades.	Diseñar plan de respuesta a incidentes para CPE; establecer canales con autoridades; desarrollar playbooks de ataques comunes.
Gestión de riesgos	0	1.4	No se contemplan amenazas cuánticas ni hay evaluación periódica o planes de mitigación en los CPE. Ausencia de alineación con TRACI, NIST o ISO 31000.	Aplicar TRACI y NIST RMF; realizar evaluaciones periódicas de riesgo; incluir amenazas cuánticas; actualizar BCP.
Criptografía y seguridad de comunicación	0	1.3	No se ha implementado criptografía post-cuántica. No existen auditorías, ni mecanismos de distribución segura de claves. TLS desactualizado.	Migrar a algoritmos post-cuánticos (Kyber, Dilithium); reforzar TLS 1.3; explorar QKD; capacitar personal en PQC.
Parches y actualizaciones	0	1.4	Aplicación reactiva de parches sin documentación ni pruebas previas. No hay rollback, trazabilidad ni clasificación de sistemas críticos.	Centralizar gestión de parches; exigir soporte extendido a fabricantes; implementar rollback; monitorear CVE y priorizar parches críticos.
Promedios y análisis	0.33	1.67	Los 6 componentes esenciales: desde el punto de vista general, todos los componentes se pueden considerar en estado planificado. Se han identificado como una necesidad importante, pero aún no se ha iniciado su implementación. Nivel de madurez de los 6	

Componentes esenciales de MoRCiTO	*MIL	*P	Hallazgos / Comentarios según C2M2	Recomendaciones según MoRCiTO
			componentes esenciales MIL0: las prácticas de los 6 componentes no se realizan. Se consideran sus implementaciones incompletas o no iniciadas.	

*P: Puntaje (Valor cuantitativo en un rango entre 0 y 6 del modelo de referencia MoRCiTO).

*MIL: puntaje (Valor cuantitativo en un rango entre 0 y 3 del nivel de madurez según el modelo C2M2).

A continuación el mapa de ruta y el plan de acción a corto, mediano y largo plazo para alcanzar y superar el umbral mínimo aceptable **MIL2**. El estado actual de madurez de los componentes esenciales del ISP: 4 de los 6 componentes están en nivel **MIL0** (entre 1.3 y 1.5 según el nivel de implementación del componente esencial del modelo de referencia MoRCiTO) y los 2 componentes restantes están en nivel **MIL1** (entre 2.1 y 2.36 según el nivel de implementación del componente esencial del modelo de referencia MoRCiTO). Meta recomendada: alcanzar al menos **MIL2** (≥ 4 según el nivel de implementación del componente esencial del modelo de referencia MoRCiTO), donde los procesos estén documentados, gestionados y optimizados. La línea roja marca el umbral mínimo aceptable.

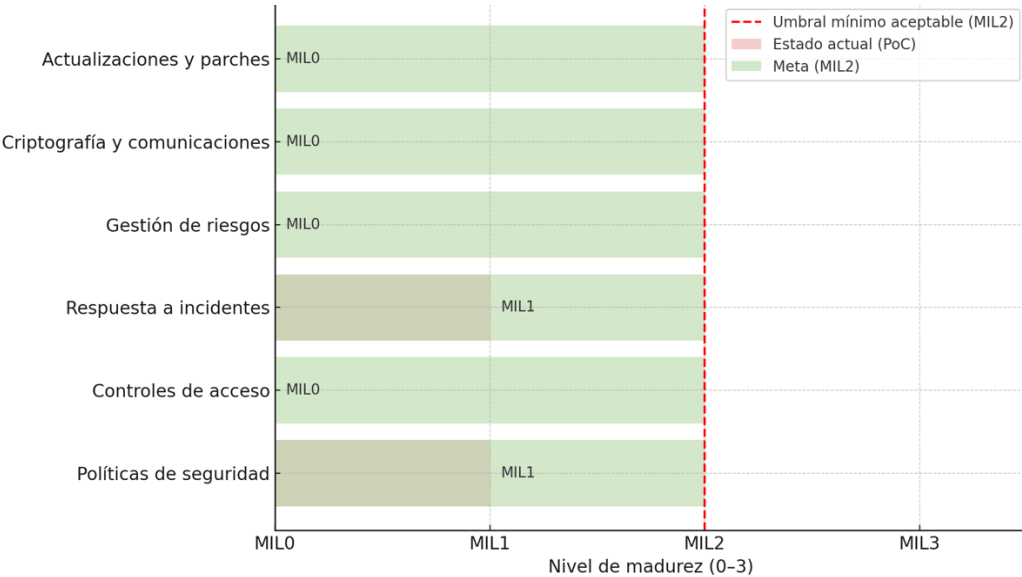


Figura 5. Mapa de ruta de los 6 componentes esenciales vs nivel de madurez **MIL**

Tabla 17. Plan de acción de mejoras para superar el umbral mínimo aceptable de madurez a corto, mediano y largo plazo según el modelo de referencia MoRCiTO.

Componentes esenciales	Corto plazo (0 - 6 meses)	Mediano plazo (6 - 18 meses)	Largo plazo (18 - 36 meses)
Políticas de ciberseguridad	Redactar políticas específicas para CPE; revisión tras incidentes.	Alinear con ISO/IEC 27001 e IEC 62443; auditorías internas.	Ciclo de mejora continua anual; lecciones aprendidas post-incidente.
Controles de acceso	Eliminar credenciales por defecto; forzar contraseñas seguras.	Implementar RBAC en CPE; habilitar MFA para accesos administrativos.	Gestión de identidades federada; adoptar Zero Trust Architecture.
Detección y respuesta a incidentes	Protocolo de reporte de vulnerabilidades; equipo mínimo CSIRT-CPE.	Playbooks de ataques comunes; comunicación con CSIRT nacional.	Automatizar con SIEM/SOAR; simulacros de crisis red/blue team.
Gestión de riesgos	Primer análisis TRACI sobre CPE; registrar vulnerabilidades (CVE/CVSS).	Integrar evaluaciones en BCP; automatizar monitoreo de vulnerabilidades.	Incluir amenazas cuánticas en mapa de riesgos; pruebas de resiliencia cibernética.

Componentes esenciales	Corto plazo (0 - 6 meses)	Mediano plazo (6 - 18 meses)	Largo plazo (18 - 36 meses)
Criptografía y seguridad de comunicación	Deshabilitar Telnet/HTTP; forzar TLS 1.2/1.3.	Plan de migración a PQC; gestión segura de claves.	Migrar completamente a PQC; pilotos con QKD en red troncal.
Parches y actualizaciones	Inventario de firmware; desplegar parches críticos en CPE expuestos.	Plataforma centralizada de actualización remota; soporte extendido de fabricantes.	Automatizar ciclo de vida de firmware; rollback seguro y sandbox.

Referencias

- [1] U. Department of Energy, “C2M2 Version 2.1 June 2022,” Jun. 2022. Accessed: Apr. 05, 2025. [Online]. Available: <https://www.energy.gov/ceser/cybersecurity-capability-maturity-model-c2m2>